

Série de TP N°3

Exercice 1 : Exemple d'une politique XACML en important un fichier et en écrivant la politique manuellement

Document : xacml_policy_etudiant.xml

- **Exemple d'une requete (Permit) :**

```
<Request xmlns="urn:oasis:names:tc:xacml:3.0:core:schema:wd-17"
```

```
  ReturnPolicyIdList="false"
```

```
  CombinedDecision="false">
```

```
    <Attributes Category="urn:oasis:names:tc:xacml:1.0:subject-category:access-subject">
```

```
      <Attribute AttributeId="http://wso2.org/claims/role" IncludeInResult="false">
```

```
        <AttributeValue
```

```
        DataType="http://www.w3.org/2001/XMLSchema#string">ETUDIANT</AttributeValue>
```

```
      </Attribute>
```

```
      <Attribute AttributeId="urn:oasis:names:tc:xacml:1.0:subject:subject-id"
```

```
      IncludeInResult="false">
```

```
        <AttributeValue
```

```
        DataType="http://www.w3.org/2001/XMLSchema#string">MOHAMED</AttributeValue>
```

```
      </Attribute>
```

```
    </Attributes>
```

```
    <Attributes Category="urn:oasis:names:tc:xacml:3.0:attribute-category:resource">
```

```
      <Attribute AttributeId="urn:oasis:names:tc:xacml:1.0:resource:resource-id"
```

```
      IncludeInResult="false">
```

```
        <AttributeValue
```

```
        DataType="http://www.w3.org/2001/XMLSchema#string">R4</AttributeValue>
```

```
      </Attribute>
```

```
    </Attributes>
```

```
    <Attributes Category="urn:oasis:names:tc:xacml:3.0:attribute-category:action">
```

```
      <Attribute AttributeId="urn:oasis:names:tc:xacml:1.0:action:action-id"
```

```
      IncludeInResult="false">
```

```

    <AttributeValue
DataType="http://www.w3.org/2001/XMLSchema#string">EXECUTER</AttributeValue>
  </Attribute>
</Attributes>

```

```

<Attributes Category="urn:oasis:names:tc:xacml:3.0:attribute-category:environment">
  <Attribute AttributeId="urn:oasis:names:tc:xacml:1.0:environment:current-time"
IncludeInResult="false">
    <AttributeValue
DataType="http://www.w3.org/2001/XMLSchema#time">09:00:00</AttributeValue>
  </Attribute>
</Attributes>

```

```

</Request>

```

- **Exemple requete 2 (Deny):**

```

<Request xmlns="urn:oasis:names:tc:xacml:3.0:core:schema:wd-17"
  ReturnPolicyIdList="false"
  CombinedDecision="false">

```

```

  <Attributes Category="urn:oasis:names:tc:xacml:1.0:subject-category:access-subject">
    <Attribute AttributeId="http://wso2.org/claims/role" IncludeInResult="false">
      <AttributeValue
DataType="http://www.w3.org/2001/XMLSchema#string">VISITEUR</AttributeValue>
    </Attribute>
    <Attribute AttributeId="urn:oasis:names:tc:xacml:1.0:subject:subject-id"
IncludeInResult="false">
      <AttributeValue
DataType="http://www.w3.org/2001/XMLSchema#string">ALI</AttributeValue>
    </Attribute>
  </Attributes>

```

```

  <Attributes Category="urn:oasis:names:tc:xacml:3.0:attribute-category:resource">

```

```

    <Attribute AttributeId="urn:oasis:names:tc:xacml:1.0:resource:resource-id"
IncludeInResult="false">

    <AttributeValue
DataType="http://www.w3.org/2001/XMLSchema#string">R4</AttributeValue>

    </Attribute>

</Attributes>

<Attributes Category="urn:oasis:names:tc:xacml:3.0:attribute-category:action">

    <Attribute AttributeId="urn:oasis:names:tc:xacml:1.0:action:action-id"
IncludeInResult="false">

    <AttributeValue
DataType="http://www.w3.org/2001/XMLSchema#string">EXECUTER</AttributeValue>

    </Attribute>

</Attributes>

<Attributes Category="urn:oasis:names:tc:xacml:3.0:attribute-category:environment">

    <Attribute AttributeId="urn:oasis:names:tc:xacml:1.0:environment:current-time"
IncludeInResult="false">

    <AttributeValue
DataType="http://www.w3.org/2001/XMLSchema#time">09:00:00</AttributeValue>

    </Attribute>

</Attributes>

</Request>

```

Exercise 2

- **Changer mot de passe utilisateur**

Home > Security > User Management > Add > Edit > Change Password

Change Password

Enter New Password

New Password*



New Password Repeat*



Change

Cancel

- **Attribuer des rôles à un utilisateur :**

Role List of User : LABIOD

Enter role name pattern (* for all) 

 *Select roles and Update to assign them to user **LABIOD***

Unassigned Roles	
Select all on this page Unselect all on this page	
☐ admin	 View Users
☐ ETUDIANT	 Permissions  View Users
☐ ADMINISTRATION	 Permissions  View Users
☐ NURSE	 Permissions  View Users
☐ DIRECTOR	 Permissions  View Users
☐ PROGRAMER	 Permissions  View Users
☐ HOUSEKEEPER	 Permissions  View Users
☐ ADMINHOSPITAL	 Permissions  View Users
Update Finish Cancel	

- **Voir les rôles d'un utilisateur :**

[Home](#) > [Identity](#) > [Users and Roles](#) > [Add](#) > [Add User](#) > [Users of Role](#)

Role List of User : LABIOD

Enter role name pattern (* for all) 

 *Select roles and Update to remove them from user*

Roles of User LABIOD	
Select all on this page Unselect all on this page	
☒ ENSEIGNANT	 Permissions  View Users
☒ Internal/everyone	 Permissions
☒ DOCTOR	 Permissions  View Users
Update Finish Cancel	

Supprimer un utilisateur en utilisant le bouton **Delete**.



Do you want to delete the user 'MOHAMED'?

Yes

No

- **Profil utilisateur :**

[Home](#) > [Identity](#) > [Users and Roles](#) > [Add](#) > [Add User](#) > [Update Profile](#)

Update Profile : LABIOD

User Profile	
Profile Name *	default
First Name *	
Last Name *	LABIOD
Organization	
Country	
Email *	
Telephone	
Mobile	
IM	
URL	
Role	ENSEIGNANT,Internal/everyone,DOCTOR
Update Cancel	

Exercice 3

Soit la liste des rôles suivant dans un Hôpital :

Name	Actions
admin	 Assign Users  View Users
ADMINHOSPITAL	 Rename  Permissions  Assign Users  View Users  Delete
DIRECTOR	 Rename  Permissions  Assign Users  View Users  Delete
DOCTOR	 Rename  Permissions  Assign Users  View Users  Delete
HOUSEKEEPER	 Rename  Permissions  Assign Users  View Users  Delete
Internal/everyone	 Permissions
NURSE	 Rename  Permissions  Assign Users  View Users  Delete
PROGRAMER	 Rename  Permissions  Assign Users  View Users  Delete

- **Renommer un Rôle :**

Home > Identity > Users and Roles > List > Roles > Rename Role

Rename Role

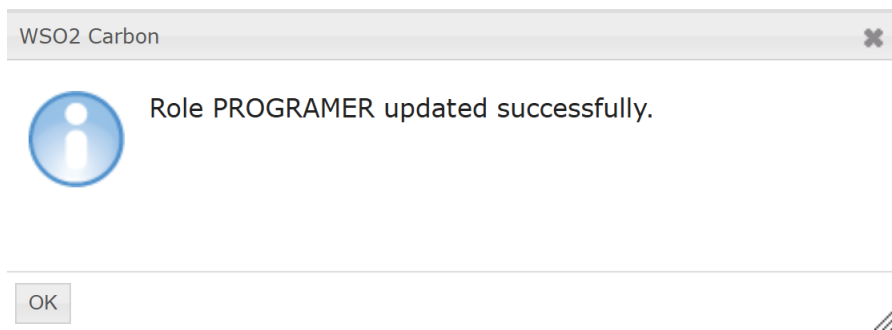
Enter role name

New role name*

PROGRAMMER

Finish

Cancel



Renommer les rôles nécessaires pour obtenir :

Name	Actions
admin	Assign Users View Users
ADMINHOSPITAL	Rename Permissions Assign Users View Users Delete
DIRECTOR	Rename Permissions Assign Users View Users Delete
DOCTOR	Rename Permissions Assign Users View Users Delete
Internal/everyone	Permissions
LABORATORY_TECHNICIAN	Rename Permissions Assign Users View Users Delete
MEDICAL_SECRETARY	Rename Permissions Assign Users View Users Delete
NURSE	Rename Permissions Assign Users View Users Delete
PHARMACIST	Rename Permissions Assign Users View Users Delete

Créer ces utilisateurs,

ELINE (NURSE)

NADINE (DOCTOR)

RASSIM (DIRECTOR)

NADIR (ADMINHOSPITAL)

ISSEF (LABORATORY TECHNICIAN)

HALIMA (PHARMACIST)

IMENE (MEDICAL SECRETARY)

Soit la liste des utilisateurs suivant :

Name	Actions
admin	Change Password Assign Roles View Roles Delete User Profile
ELINE	Change Password Assign Roles View Roles Delete User Profile
HALIMA	Change Password Assign Roles View Roles Delete User Profile
IMENE	Change Password Assign Roles View Roles Delete User Profile
ISSEF	Change Password Assign Roles View Roles Delete User Profile
NADINE	Change Password Assign Roles View Roles Delete User Profile
NADIR	Change Password Assign Roles View Roles Delete User Profile
RASSIM	Change Password Assign Roles View Roles Delete User Profile

Soit la politique de sécurité suivante :

ROLE: DOCTOR

- Lire et mettre à jour les dossiers médicaux des patients
- Prescrire des médicaments dans le système pharmaceutique
- Demander des analyses via le système de laboratoire

ROLE: NURSE

- Lire les dossiers médicaux des patients
- Mettre à jour les constantes vitales dans les dossiers médicaux
- Administrer les traitements prescrits et enregistrer l'administration

ROLE: PHARMACIST

- Lire les prescriptions médicales
- Préparer et délivrer les médicaments
- Mettre à jour le stock de médicaments

ROLE: LABORATORY TECHNICIAN

- Lire les demandes d'analyses médicales
- Enregistrer les résultats d'analyses dans le système

ROLE: MEDICAL SECRETARY

- Lire et mettre à jour les informations administratives des patients
- Planifier les rendez-vous médicaux
- Gérer les admissions et les sorties

Create XACML Policy

Entitlement Policy Name*	POLICY_HOSPITAL		
Entitlement Policy Description	politique de sécurité qui concerne l'hôpital ibn rochd de la wilaya		
This policy is based on	Environment ▾		
Environment which	Domain ▾	is equals to	IBN_ROCHD

Resource	DOSSIER_MEDICAUX	User	Role ▾	DOCTOR		Action	LIRE	
Resource	DOSSIER_MEDICAUX	User	Role ▾	DOCTOR		Action	UPDATE	
Resource	ANALYSE	User	Role ▾	DOCTOR		Action	DEMANDER	
Resource	DOSSIER_MEDICAUX	User	Role ▾	NURSE		Action	LIRE	
Resource	DOSSIER_MEDICAUX	User	Role ▾	NURSE		Action	UPDATE	

Resource	TRAITEMENT	User	Role	NURSE	Action	ADMINISTRER	
Resource	PRESCRIPTIONS_MEDICA	User	Role	PHARMACIST	Action	LIRE	
Resource	MEDICAMENTS	User	Role	PHARMACIST	Action	PREPARER	
Resource	MEDICAMENTS	User	Role	PHARMACIST	Action	DELIVRER	
Resource	STOCK	User	Role	PHARMACIST	Action	UPDATE	
Resource	DEMANDES_ANALYSE	User	Role	LABORATORY_TECHNICIAN	Action	LIRE	
Resource	ANALYSE	User	Role	LABORATORY_TECHNICIAN	Action	ECRIRE	
Resource	RDV	User	Role	MEDICAL_SECRETARY	Action	PLANIFIER	
Resource	DOSSIER_ADMINISTRATIF	User	Role	MEDICAL_SECRETARY	Action	LIRE	
Resource	DOSSIER_ADMINISTRATIF	User	Role	MEDICAL_SECRETARY	Action	UPDATE	
Resource	ADMISSION	User	Role	MEDICAL_SECRETARY	Action	GERER	
Resource	SORTIE	User	Role	MEDICAL_SECRETARY	Action	GERER	

Finish Cancel

Ajouter la politique au PAP :

WSO2 Carbon



Entitlement policy is added to PAP policy store successfully.

OK

Publier la politique au PDP :

☒	POLICY_HOSPITAL		Edit	Versions	Publish To My PDP	Try	View Status
☐	POLICY_LAST		Edit	Versions	Publish To My PDP	Publish To My PDP	View Status

Tester la politique :

Requête 1 :

TryIt

 Create Request Using Editor

Evaluation is done with one policy which policy id is **POLICY_HOSPITAL**

☐ Multiple Request ☐ Return Policy List

Resource ☐ Include In Result

Subject Name ☐ Include In Result

Action Name ☐ Include In Result

Environment Name ☐ Include In Result

Résultat :

 Create Request Using Editor

Evaluation is done with

☐ Multiple Request

Resource

Subject Name

Action Name

Environment Name

☐ Include In Result

☐ Include In Result

☐ Include In Result

☐ Include In Result

Requête 2 :

Home > Entitlement > PAP > Policy Administration

TryIt

Create Request Using Editor

Evaluation is done with one policy which policy id is **POLICY_HOSPITAL**

☐ Multiple Request ☐ Return Policy List

Resource: ☐ Include In Result

Subject Name: ☐ Include In Result

Action Name: ☐ Include In Result

Environment Name: ☐ Include In Result

Résultat :

Home > Entitlement > PAP > Policy Administration > Create Evaluation Request

TryIt

Create Request Using Editor

Evaluation is done with one policy which policy id is **POLICY_HOSPITAL**

☐ Multiple Request

Resource: ☐ Include In Result

Subject Name: ☐ Include In Result

Action Name: ☐ Include In Result

Environment Name: ☐ Include In Result

WSO2 Carbon

Permit

OK

Requête 3 :

TryIt

Create Request Using Editor

Evaluation is done with one policy which policy id is **POLICY_HOSPITAL**

☐ Multiple Request ☐ Return Policy List

Resource: ☐ Include In Result

Subject Name: ☐ Include In Result

Action Name: ☐ Include In Result

Environment Name: ☐ Include In Result

WSO2 Carbon

Deny

OK

- `<Rule Effect="Deny" RuleId="Deny-Rule"/>`

Ce code présente une règle appelée Deny-Rule, Effect="Deny" signifie que cette règle refuse l'accès, Il n'y a pas de condition attachée. Cela veut dire que si aucune autre règle avant ne donne la permission, alors cette règle s'applique.

- **Explication d'une règle (règle 10 de la politique proposée) :**

```
<Rule Effect="Permit" RuleId="Rule-10">
  <Target>
    <AnyOf>
      <AllOf>
        <Match MatchId="urn:oasis:names:tc:xacml:1.0:function:string-equal">
          <AttributeValue DataType="http://www.w3.org/2001/XMLSchema#string">STOCK</AttributeValue>
          <AttributeDesignator AttributeId="urn:oasis:names:tc:xacml:1.0:resource:resource-id"
            Category="urn:oasis:names:tc:xacml:3.0:attribute-category:resource"
            DataType="http://www.w3.org/2001/XMLSchema#string" MustBePresent="true"/>
        </Match>
      </AllOf>
    </AnyOf>
    <AnyOf>
      <AllOf>
        <Match MatchId="urn:oasis:names:tc:xacml:1.0:function:string-equal">
          <AttributeValue DataType="http://www.w3.org/2001/XMLSchema#string">UPDATE</AttributeValue>
          <AttributeDesignator AttributeId="urn:oasis:names:tc:xacml:1.0:action:action-id"
            Category="urn:oasis:names:tc:xacml:3.0:attribute-category:action" DataType="http://www.w3.org/2001/XMLSchema#string" MustBePresent="true"/>
        </Match>
      </AllOf>
    </AnyOf>
  </Target>
  <Condition>
    <Apply FunctionId="urn:oasis:names:tc:xacml:1.0:function:any-of">
      <Function FunctionId="urn:oasis:names:tc:xacml:1.0:function:string-equal"/>
      <AttributeValue DataType="http://www.w3.org/2001/XMLSchema#string">PHARMACIST</AttributeValue>
      <AttributeDesignator AttributeId="http://wso2.org/claims/role" Category="urn:oasis:names:tc:xacml:1.0:subject-category:access-subject"
        DataType="http://www.w3.org/2001/XMLSchema#string" MustBePresent="true"/>
    </Apply>
  </Condition>
</Rule>
```

```
<Rule Effect="Permit" RuleId="Rule-10">
```

- Tu définis une règle appelée **Rule-10**
- **Effect="Permit"** veut dire qu'elle autorise l'accès si tout est correct

```
<Target>
```

- Tu définis ce sur quoi la règle s'applique
- Le **Target** vérifie deux choses ensemble

```

<AnyOf>
  <AllOf>
    <Match MatchId="string-equal">
      <AttributeValue>STOCK</AttributeValue>
      <AttributeDesignator AttributeId="resource-id"/>
    </Match>
  </AllOf>
</AnyOf>

```

- La ressource demandée doit être **STOCK**
- Cela veut dire que l'utilisateur veut accéder au stock (par exemple les médicaments en réserve)

```

<AnyOf>
  <AllOf>
    <Match MatchId="string-equal">
      <AttributeValue>UPDATE</AttributeValue>
      <AttributeDesignator AttributeId="action-id"/>
    </Match>
  </AllOf>
</AnyOf>

```

- L'action demandée doit être **UPDATE**
- Donc l'utilisateur veut **modifier** le stock

```
<Condition>
  <Apply FunctionId="any-of">
    <Function FunctionId="string-equal"/>
    <AttributeValue>PHARMACIST</AttributeValue>
    <AttributeDesignator AttributeId="role"/>
  </Apply>
</Condition>
```

- L'utilisateur doit avoir le rôle **PHARMACIST**
- Sinon, même si la ressource et l'action correspondent, il sera bloqué

Résumé clair

- Si la ressource = **STOCK**
- Si l'action = **UPDATE**
- Si l'utilisateur a le rôle = **PHARMACIST**
- Alors **autoriser l'accès**

Sinon, la règle ne s'applique pas

"la règle ne s'applique pas" ne veut pas dire "accès denied" directement

Voici ce qui se passe exactement

- Si une règle **ne s'applique pas**, le moteur XACML continue à chercher d'autres règles
- Si aucune autre règle **Permit** ne correspond
- Alors c'est la règle par défaut (comme **Deny-Rule**) qui s'active
- Et là, oui, **accès denied**